Cloud Attack Paths and Evidence-Driven Defense Workshop

Original curriculum for a two-day internal workshop inspired by the public scope of the DEF CON Training page for "Breaking the Cloud Layer - Modern and Practical Attacks on AWS, Azure, GCP, Aliyun, Railway and Vercel".

Reference reviewed: https://training.defcon.org/products/breaking-the-cloud-practical-attacks-on-aws-azure-gcp-digitalocean-and-aliyun-anant-shrivastava-dctlv2026

Workshop Positioning

This workshop teaches how cloud compromises happen as chains, not isolated misconfigurations. Participants work inside authorized vulnerable lab accounts, follow realistic attacker workflows at a controlled level, collect evidence from the environment, then verify the same issues through scanner outputs and compliance dashboard evidence.

The workshop is not a public-target hacking class. Every activity must run only in prepared lab tenants, disposable cloud projects, or local container environments where the organization has explicit authorization.

Target Audience

- Cloud security engineers
- DevOps, SRE, and platform engineers
- Security analysts who triage cloud findings
- GRC and compliance engineers who need evidence mapping
- Product engineers building cloud scanners, evidence connectors, and dashboards

Difficulty

Intermediate to advanced.

Participants should already be comfortable with Linux CLI, HTTP basics, cloud consoles, IAM concepts, and reading Terraform or Kubernetes YAML. They do not need deep Kubernetes or multi-cloud expertise before attending.

Learning Outcomes

By the end of the workshop, participants should be able to:

- Explain common multi-cloud attack paths from external exposure to cloud control-plane impact.
- Identify high-risk cloud weaknesses across IAM, storage, metadata services, serverless, data stores, containers, Kubernetes, IaC, CI/CD, and AI integrations.
- Collect and normalize evidence from scanners, cloud APIs, logs, and uploaded files.
- Map technical evidence to controls, severity, owners, and remediation status.

- Use CloudGuard-style scanner output to support compliance dashboard findings.
- Design safer tenant-separated scanner workflows using `tenant_id`, connector contracts, queues, and evidence processors.
- Present attack path risk to leadership without relying on vendor-specific jargon.

Workshop Format

- Duration: 2 days
- Daily time: 8 hours including breaks
- Delivery mode: Instructor-led, lab-heavy, with team-based capstone
- Lab model: Disposable vulnerable accounts/projects only
- Main deliverables from each team:
  - Attack path worksheet
  - Evidence bundle
  - Scanner result export
  - Control mapping
  - Remediation plan
  - Five-minute executive brief

Lab Architecture

The workshop uses a decoupled scanner and evidence architecture:

- Vulnerable lab tenants: separate cloud accounts/projects/subscriptions for each team.
- Scanner workers: AWS, GCP, Kubernetes, and IaC scanners run separately from the portal.
- Evidence connectors: each scanner emits normalized evidence payloads.
- Ingestion gateway: validates payload schema, stores uploaded artifacts temporarily, and pushes work to the queue.
- Message queue: decouples scanner jobs from portal availability.
- Evidence processor: stores artifacts permanently, deduplicates findings, and maps them to controls.
- Compliance dashboard: shows risk, ownership, remediation status, and audit evidence.
- Tenant isolation: every evidence item, scan job, credential reference, asset, finding, and control mapping carries `tenant_id`.

Safety Rules

- Use only approved lab accounts, disposable projects, and local test clusters.
- Do not scan public targets, third-party infrastructure, or personal accounts.
- Use least-privilege lab credentials with spending alerts and budget limits.
- Rotate or destroy lab credentials after the workshop.
- Keep all findings inside the workshop evidence system.
- Do not store real production secrets in lab files.

- Do not run destructive payloads unless the instructor explicitly marks the lab as disposable.

Pre-Workshop Setup

Students should complete this one week before the workshop:

- Install a modern browser, terminal, Git, Docker, and an SSH client.
- Install Terraform, kubectl, and a code editor.
- Confirm access to a disposable cloud account or instructor-provided lab account.
- Confirm outbound HTTPS access to cloud APIs.
- Confirm access to the workshop repository and lab guide.
- Verify that no production credentials are present in `.env`, shell history, or local config files.

Instructor should prepare:

- Lab account templates with budgets and region restrictions.
- Terraform modules for each vulnerable environment.
- Reset and cleanup scripts.
- Evidence connector schema examples.
- Scanner worker compose files.
- Known-good vulnerable IaC bundle.
- Capstone scoring spreadsheet.
- Hardening checklist mapped to controls.

Day 1 Agenda

09:00 - 09:30 Module 0: Orientation and Setup

Objective: Establish the rules of engagement, confirm lab access, and explain the evidence-driven workflow.

Topics: - Workshop scope and authorization boundaries - Lab account structure - CloudGuard portal, scanner workers, and connector flow - Evidence schema and `tenant_id` segregation - How teams will be scored

Hands-on: - Log in to the portal - Select assigned tenant - Trigger a dry-run scanner job - Upload a sample evidence file - Verify that evidence appears under the correct tenant

Evidence collected: - `scan_job.created` - `evidence.accepted` - `tenant_id` validation result

09:30 - 10:30 Module 1: Multi-Cloud Attack Path Mindset

Objective: Understand cloud breaches as a chain across identity, network exposure, storage, automation, and control-plane permissions.

Topics: - Why cloud compromise is usually multi-step - Asset exposure versus identity exposure - Control plane versus data plane - Common patterns across AWS, Azure, GCP, DigitalOcean, and developer platforms - How attack paths become compliance findings

Hands-on: - Review a sample breach story - Convert the story into an attack graph - Identify where scanner evidence would have detected the weakness

Evidence collected: - Attack path graph - Control mapping draft

10:45 - 12:15 Module 2: Recon to First Foothold

Objective: Learn how exposed assets, public metadata, leaked artifacts, and weak configuration become initial access paths in a lab environment.

Topics: - Asset inventory gaps - Public buckets and object stores - Exposed admin panels and debug endpoints - Misconfigured DNS and stale records - Leaked build artifacts and environment files - Safe recon inside owned lab ranges

Hands-on: - Enumerate assigned lab assets - Identify intentional public exposures - Capture evidence for each exposure - Run cloud inventory scanner and compare results

Evidence collected: - Exposed asset list - Screenshot or API response artifact - Scanner finding export - Owner and severity assignment

13:15 - 14:30 Module 3: Storage and Artifact Exposure

Objective: Understand how object storage, build artifacts, logs, and backups leak sensitive material.

Topics: - Public object storage risks - Over-broad bucket policies - Backup and log exposure - Secrets in build artifacts - Evidence handling for sensitive files - Remediation patterns

Hands-on: - Inspect a vulnerable storage configuration - Identify sensitive artifact classes - Validate scanner detection - Draft a minimal remediation policy

Evidence collected: - Bucket or container policy snapshot - Object listing evidence - Scanner finding - Remediation diff

14:45 - 16:00 Module 4: SSRF, Metadata, and Cloud Identity

Objective: Understand the relationship between SSRF-style application weaknesses, metadata services, and short-lived cloud credentials.

Topics: - Metadata service purpose and risk - Instance identities and managed identities - Session credential exposure - Network controls that reduce metadata abuse - Why metadata findings need application and cloud owners together

Hands-on: - Review a controlled SSRF lab path - Trace how application exposure becomes cloud identity exposure - Use scanner output to identify risky metadata and identity configuration - Write a two-owner remediation note

Evidence collected: - Metadata risk evidence - Identity permission snapshot - Scanner output - Cross-owner remediation note

16:00 - 17:00 Module 5: Serverless and Data Tier Attacks

Objective: Learn how serverless functions, managed databases, queues, and secrets stores create lateral movement paths.

Topics: - Over-privileged function roles - Environment variables and secrets - Managed database network exposure - Queue-triggered workflows - Logging and detection opportunities

Hands-on: - Review a vulnerable serverless function configuration - Identify sensitive environment variables - Compare manual review with scanner results - Map findings to compliance controls

Evidence collected: - Function configuration evidence - Secret exposure class - Database exposure result - Control mapping

Day 2 Agenda

09:00 - 10:15 Module 6: Containers and Kubernetes

Objective: Understand how image, workload, RBAC, network policy, and secret weaknesses create cluster risk.

Topics: - Container image risk - Privileged workloads - Service accounts and RBAC - Network policy gaps - Namespace boundaries - Kubernetes evidence from kubeconfig-based scanning

Hands-on: - Scan a test cluster through kubeconfig - Review pods, services, namespaces, RBAC, secrets, and network policies - Compare deployed cluster state against IaC manifests - Prioritize fixes by blast radius

Evidence collected: - Cluster inventory - RBAC findings - Network policy findings - IaC drift comparison

10:30 - 11:45 Module 7: Deep Cloud-Native Abuse and IAM Escalation

Objective: Recognize privilege escalation paths caused by excessive permissions, trust policies, service agents, and automation identities.

Topics: - Identity graph thinking - Dangerous permissions and role chaining - Service-linked identities - CI/CD identities - Permission boundaries and deny policies - Evidence for auditors versus evidence for engineers

Hands-on: - Build an identity graph from lab permissions - Mark escalation edges - Validate through scanner findings - Draft remediation with least privilege and break-glass exceptions

Evidence collected: - Identity graph - High-risk permission list - Scanner evidence - Least-privilege remediation plan

12:45 - 14:00 Module 8: Provider-Specific Kill Chains

Objective: Compare how similar weaknesses look across AWS, Azure, GCP, DigitalOcean, and developer platforms.

Topics: - AWS IAM, S3, Lambda, EC2 metadata, EKS - Azure Entra ID, managed identity, storage accounts, functions, AKS - GCP IAM, service accounts, Cloud Storage, Cloud Functions, GKE - DigitalOcean projects, spaces, droplets, container registry, managed databases, Kubernetes - Developer platforms such as Vercel and Railway as cloud-adjacent control planes

Hands-on: - Review four provider mini-cases - Identify equivalent control points - Write normalized evidence records for each provider

Evidence collected: - Provider comparison table - Normalized evidence payloads - Control equivalence map

14:00 - 15:00 Module 9: CI/CD, Developer Platforms, and AI Integrations

Objective: Understand how code automation, deployment platforms, model integrations, and over-privileged AI workflows increase cloud risk.

Topics: - CI/CD secrets and OIDC trust - Deployment tokens - Build logs and artifacts - AI agents with cloud permissions - Model-hosted workflows on private VMs or Proxmox - Cost and containment for AI-assisted scanning

Hands-on: - Review a vulnerable CI/CD workflow - Identify excessive cloud permissions - Create an evidence connector payload for a CI/CD finding - Draft AI integration guardrails

Evidence collected: - Workflow risk evidence - Secret exposure class - AI permission boundary recommendation - Connector payload

15:15 - 16:00 Module 10: Defenses That Actually Work

Objective: Convert findings into durable controls that reduce recurring cloud risk.

Topics: - Preventive controls - Detective controls - Least privilege - Network egress controls - Secrets hygiene - IaC policy checks - Runtime monitoring - Evidence retention - Tenant-aware dashboards

Hands-on: - Pick three findings from previous labs - Map each to prevention, detection, and evidence requirements - Create remediation tickets with owner, severity, due date, and proof

Evidence collected: - Control matrix - Remediation ticket examples - Evidence retention labels

16:00 - 17:00 Capstone

Objective: Demonstrate end-to-end understanding through a controlled attack-path investigation and compliance evidence workflow.

Scenario: A new tenant has onboarded a cloud environment. Several intentional weaknesses exist across IaC, cloud IAM, storage, Kubernetes, and CI/CD. Teams must identify the highest-risk attack path, collect evidence, validate with scanners, and present remediation.

Team deliverables: - Attack path narrative - Scanner results - Evidence connector payloads - Dashboard findings - Control mapping - Remediation plan - Five-minute leadership briefing

Scoring: - 20 points: Accurate attack path - 20 points: Evidence quality and tenant segregation - 20 points: Scanner validation and deduplication - 15 points: Control mapping - 15 points: Remediation quality - 10 points: Executive communication

Required Vulnerable Lab Components

AWS Lab

Purpose: Validate cloud IAM, storage, metadata, serverless, and evidence ingestion coverage.

Intentional weaknesses: - Over-broad read-only role with risky metadata visibility - Public or overly permissive object storage - Serverless function with excessive permissions - Security group with unnecessary exposure - CloudTrail or logging gap - Test secret placed in a lab-only artifact

Scanner coverage: - IAM permissions - Object storage policy - Compute metadata posture - Serverless permissions - Network exposure - Logging status

GCP Lab

Purpose: Validate service account, bucket, project IAM, function, and asset inventory checks.

Intentional weaknesses: - Over-privileged service account - Public bucket or risky IAM binding - Function with excessive service account permissions - Weak logging or audit setting - Lab-only exposed artifact

Scanner coverage: - IAM bindings - Cloud Storage exposure - Service account key and role risk - Function permissions - Audit logging posture

Kubernetes Lab

Purpose: Validate live cluster scanning through kubeconfig and IaC drift comparison.

Intentional weaknesses: - Privileged pod - Default namespace workload - Over-broad service account - Missing network policy - Exposed service - Secret mounted into unnecessary workload - Deployed state drift from IaC manifest

Scanner coverage: - Pods - Services - Namespaces - RBAC - Network policies - Secrets exposure patterns - IaC versus live state drift

IaC Lab

Purpose: Validate scanning of complete uploaded files and repositories.

Intentional weaknesses: - Public storage policy in Terraform - Wide IAM permission in Terraform - Exposed security group rule - Kubernetes manifest with privileged container - Hardcoded lab-only secret - Missing tags, owner, and environment labels - Drift against live deployment

Scanner coverage: - Terraform - Kubernetes YAML - Docker Compose or deployment manifests - Secrets detection - Policy-as-code findings - Control mapping

Evidence Connector Contract

Every connector should emit a normalized payload with these fields:

```
{
  "tenant_id": "tenant_demo_001",
  "source_system": "aws_scanner",
  "scanner_type": "cloud",
  "scan_job_id": "scan_2026_06_11_001",
  "asset_id": "aws:s3:::lab-public-artifacts",
  "asset_type": "object_storage",
  "provider": "aws",
  "region": "ap-south-1",
  "finding_id": "finding_public_storage_001",
  "title": "Object storage allows unintended public access",
  "severity": "high",
  "control_ids": ["A.1.3.7", "IAM-02", "DATA-04"],
  "evidence_type": "policy_snapshot",
  "evidence_uri": "evidence://tenant_demo_001/scan_2026_06_11_001/policy.json",
  "observed_at": "2026-06-11T10:00:00Z",
  "status": "open",
  "remediation": "Restrict public access and require explicit least-privilege principals
}
```

Connector requirements: - Always include `tenant_id`. - Never accept evidence without schema validation. - Store raw artifacts separately from normalized finding records. - Deduplicate by tenant, asset, scanner, finding class, and observed condition. - Preserve scan job lineage. - Mark credentials by reference only; never store raw secrets in findings.

Multi-Tenant Database Guidance

Minimum tables should include:

- `tenants`
- `users`
- `tenant_memberships`
- `credential_references`
- `scan_jobs`
- `scanner_runs`

- `assets`
- `findings`
- `evidence_artifacts`
- `controls`
- `control_mappings`
- `remediation_tasks`
- `audit_events`

Tenant segregation rules: - Every scanner-facing table must include `tenant_id`. - Every query must filter by `tenant_id`. - Use composite indexes such as `(tenant_id, scan_job_id)`, `(tenant_id, asset_id)`, and `(tenant_id, severity, status)`. - Use row-level security where supported. - Store provider credentials as encrypted references scoped to tenant and scanner type. - Keep cross-tenant analytics in aggregated tables only after removing raw secrets and tenant-sensitive details.

Assessment Rubric

Pass criteria: - Student can explain the attack path clearly. - Student can show evidence without leaking secrets. - Student can prove the scanner found or missed the condition. - Student can map findings to controls. - Student can recommend realistic remediation.

Merit criteria: - Student identifies blast radius and root cause. - Student distinguishes prevention, detection, and evidence retention. - Student proposes a tenant-safe connector improvement. - Student quantifies risk in leadership-friendly language.

Suggested Team Roles

- Cloud operator: deploys and resets lab resources.
- Investigator: follows the lab scenario and documents findings.
- Evidence owner: uploads or validates evidence connector payloads.
- Dashboard owner: maps findings to controls and remediation.
- Presenter: delivers final executive briefing.

Post-Workshop Outputs

- Hardened lab repository
- Scanner improvement backlog
- Evidence connector schema
- Multi-tenant database contract
- Compliance dashboard backlog
- Cloud control hardening checklist
- Cost and deployment recommendation for scanner workers

Boss-Friendly Summary

We are turning the workshop into a practical multi-cloud security exercise where teams use isolated vulnerable lab accounts, run decoupled scanner jobs, ingest normalized evidence through connectors, and prove the findings inside the compliance dashboard. The focus is not just finding cloud misconfigurations, but showing how evidence moves from scanner to dashboard with `tenant_id` segregation, control mapping, remediation ownership, and audit-ready proof.